



Universidad Mariano Gálvez de Guatemala

Sede El Naranjo

Facultad de Ingeniería en Sistemas de Información

Ingeniería en Ciencias y Sistemas

Seguridad y Auditoría de Sistemas

PROYECTO DE CURSO

Propuesta de Solución de Seguridad para una Plataforma de Comercio Electrónico (E-Commerce SaaS)

Implementación de un Web Application Firewall bajo la norma ISO/IEC 27001

Integrantes

Diego Antonio Beteta García — 9490-22-12878

Jonathan Rogelio Herrera Soto — 9490-22-11551

Mario Roberto Rompich Yoc — 9490-17-1752

Guatemala, 17 de agosto de 2026

1. Modelo de Negocio

Nombre de la organización: MarketGT, plataforma de comercio electrónico bajo modelo de software como servicio (SaaS) orientada a pequeñas y medianas empresas del mercado guatemalteco que necesitan vender en línea sin administrar su propia infraestructura tecnológica.

Misión: Proporcionar una experiencia de compra en línea rápida, accesible y confiable, conectando a los usuarios con productos mediante una plataforma digital segura que proteja sus transacciones y credenciales.

Visión: Ser la plataforma de comercio electrónico referente en el mercado regional, destacando por la innovación tecnológica, la privacidad del cliente y la excelencia en auditoría e infraestructura defensiva.

Objetivos

- **Asegurar la continuidad operativa.** Garantizar una disponibilidad del servicio del 99.9 % frente a intentos de ataques de denegación de servicio o fallos del sistema.
- **Mitigar vulnerabilidades en la capa de aplicación.** Reducir a niveles tolerables el riesgo de ciberataques comunes en aplicaciones web, como las inyecciones SQL y el Cross-Site Scripting (XSS).
- **Proteger las credenciales e información del usuario.** Erradicar la exposición no autorizada de datos de pago y contraseñas frente a engaños o brechas.
- **Sostener la mejora continua.** Auditar trimestralmente los controles implementados conforme al ciclo SKiP y al Anexo A de la norma ISO/IEC 27001:2022.

Administración y Organización

La estructura organizacional se distribuye en tres niveles de decisión, tal como plantea el modelo de gestión de la seguridad de la información.

- **Nivel estratégico.** Dirección General y Director de Seguridad de la Información (CISO), encargados de establecer la política global de seguridad y de aprobar el presupuesto del proyecto.
- **Nivel táctico.** Gerencia de Operaciones y Arquitecto de Seguridad, responsables de diseñar el plano de defensas, clasificar los activos de información y definir las reglas del WAF.
- **Nivel operativo.** Departamento de TI y Hacker Ético (analista de vulnerabilidades), dedicados al monitoreo continuo, el soporte, el desarrollo seguro y la atención de incidentes.

Tabla 1

Matriz de responsabilidades por nivel organizacional

Nivel	Responsable	Función principal en la solución de seguridad
Estratégico	Dirección General y CISO	Aprobar la política de seguridad, el presupuesto y el apetito de riesgo.
Táctico	Gerencia de Operaciones y Arquitecto de Seguridad	Diseñar el esquema por capas, clasificar activos y definir el umbral de anomalía del WAF.
Operativo	Departamento de TI y Hacker Ético	Configurar, monitorear y auditar los controles; ejecutar pruebas de intrusión.

Nota. La distribución en tres niveles permite separar la definición de la política (estratégico) de su implementación técnica (operativo), lo que evita conflictos de interés durante la auditoría.

2. Tipo de Solución de Seguridad: Software

La solución seleccionada corresponde al ámbito del soporte lógico o software. Se descarta una solución basada en hardware dedicado porque el modelo de negocio opera sobre infraestructura

virtualizada en la nube, donde el punto de exposición no es el perímetro físico sino la capa 7 del modelo OSI, es decir, la aplicación web publicada en Internet.

Propuesta de seguridad: implementación de un **Web Application Firewall (WAF)** combinado con un **esquema permisivo (*hardening* de servicios)** en el sistema operativo, el servidor web y el gestor de bases de datos.

Detalle Técnico de la Solución

1. **Aseguramiento mediante *hardening*.** Se deshabilitan todas las funciones, puertos y servicios no esenciales del servidor, permitiendo únicamente lo estrictamente necesario para la operación del comercio electrónico.
2. **Filtrado en capa 7.** El WAF inspecciona el tráfico HTTP y HTTPS entrante para bloquear patrones maliciosos de Cross-Site Scripting (14.69 %), inyección SQL (5.55 %) y explotación de componentes vulnerables (12.36 %) antes de que alcancen la base de datos.
3. **Mecanismos de autenticación robusta.** Se restringe el acceso a los paneles administrativos mediante autenticación multifactor, con lo que se previenen los ataques de fuerza bruta y los fallos de autenticación débil (9.25 %).
4. **Ciclo activo de defensa (modelo SKiP).** Se aplican de forma continua las cinco fases de asegurar, preparar, detectar, responder y mejorar para gestionar los parches de software y las actualizaciones ante nuevos hallazgos.

Justificación de la Elección

Un WAF es un control compensatorio: protege la aplicación incluso cuando el código contiene un defecto todavía no corregido. Esta característica resulta decisiva en una plataforma SaaS que publica actualizaciones con frecuencia y donde el tiempo entre la divulgación de una

vulnerabilidad y su corrección representa la ventana real de exposición. Adicionalmente, la versión 4.0 del estándar PCI DSS establece en su requisito 6.4.2 que toda aplicación web pública que procese datos de tarjetas debe contar con una solución técnica automatizada de este tipo, obligación vigente desde el 31 de marzo de 2025.

3. Presentación de Lógica Funcional

La lógica funcional describe el recorrido completo de una petición desde el navegador del cliente hasta la base de datos, señalando los puntos donde la solución evalúa y, si corresponde, interrumpe el flujo. El principio rector es la evaluación temprana: el tráfico ilegítimo se descarta en el punto más externo posible, de modo que nunca consuma recursos del servidor de aplicaciones.

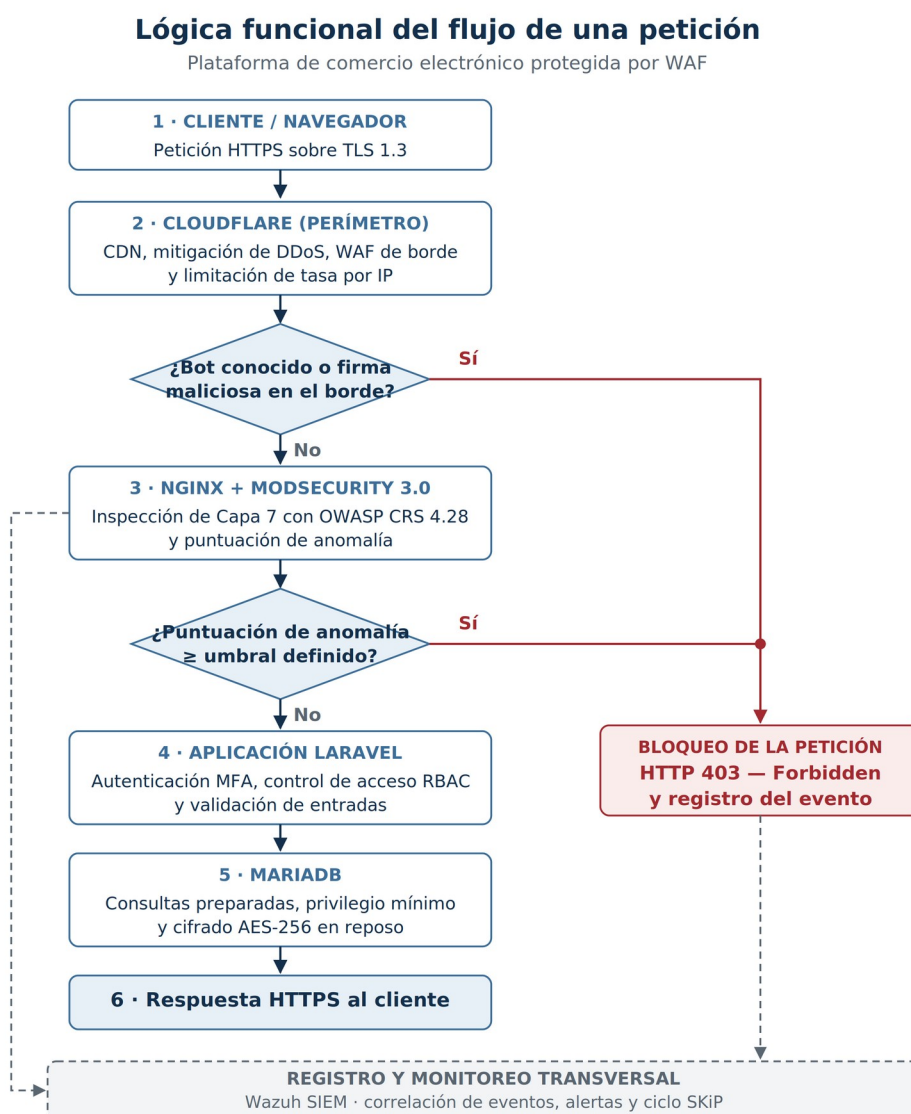
Descripción del Flujo

1. El cliente emite una petición HTTPS cifrada con TLS 1.3 desde su navegador.
2. Cloudflare recibe la petición en el borde de la red y aplica mitigación de denegación de servicio, entrega de contenido estático desde caché y limitación de tasa por dirección IP.
3. Primer punto de decisión. Si la petición corresponde a un bot conocido o coincide con una firma maliciosa del conjunto de reglas gestionado, se descarta en el borde y el flujo termina.
4. El tráfico que supera el filtro llega a Nginx, donde ModSecurity evalúa la petición contra el OWASP Core Rule Set y asigna una puntuación de anomalía acumulada.
5. Segundo punto de decisión. Si la puntuación iguala o supera el umbral configurado, el servidor responde con un código HTTP 403 y registra el evento con la regla que se activó.
6. La petición legítima ingresa a la aplicación Laravel, que verifica la sesión, exige autenticación multifactor en las rutas administrativas, aplica el control de acceso basado en roles y valida todos los datos de entrada.
7. La consulta a MariaDB se ejecuta mediante sentencias preparadas, con un usuario de base de datos limitado al privilegio mínimo necesario y con los campos sensibles cifrados en reposo.

8. La respuesta se devuelve al cliente sobre HTTPS, acompañada de las cabeceras de seguridad Content-Security-Policy y Strict-Transport-Security.
9. De forma transversal, cada etapa envía sus registros a Wazuh, que correlaciona los eventos, genera alertas y alimenta la fase de mejora del ciclo SKiP.

Figura 1

Lógica funcional del flujo de una petición en la plataforma



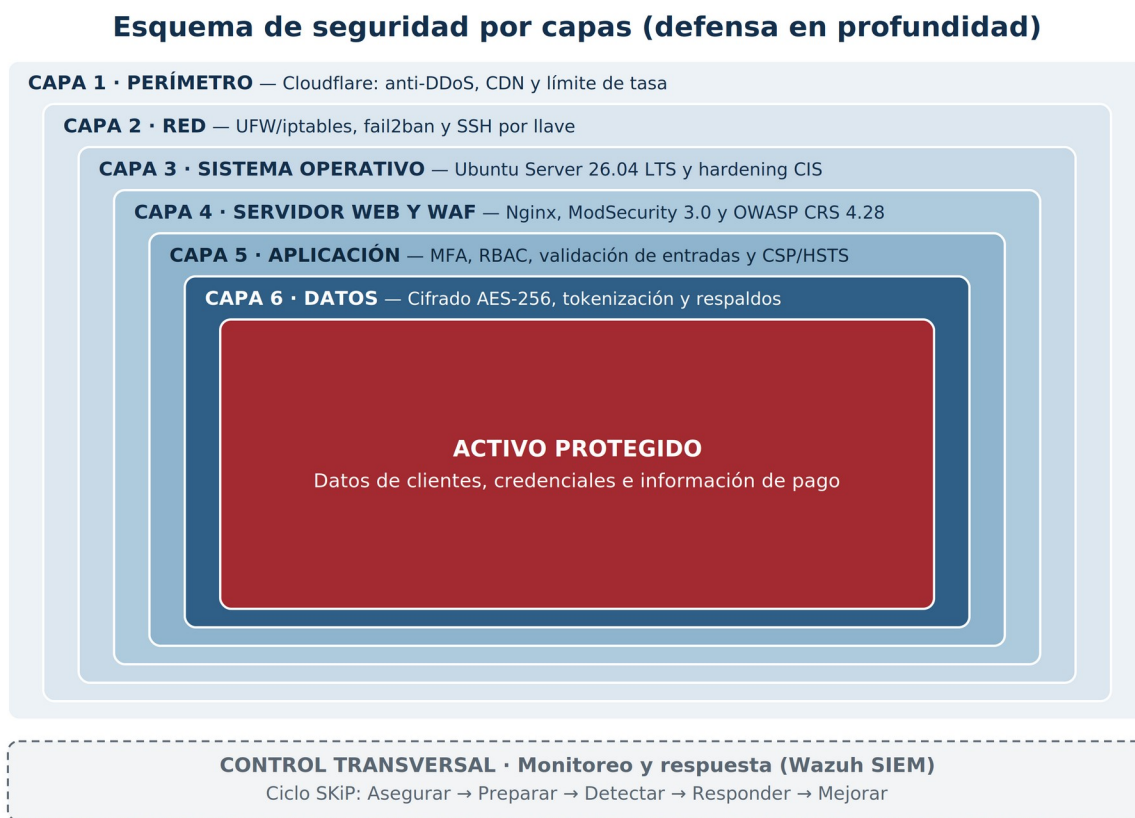
Nota. El recorrido en color oscuro representa el flujo legítimo y el recorrido en color rojo representa la ruta de denegación. Los dos rombos corresponden a los puntos de decisión del WAF de borde y del WAF local. La banda inferior indica el registro transversal que alimenta el ciclo de mejora continua.

4. Esquema de Seguridad

El esquema adoptado es de defensa en profundidad: seis capas concéntricas de control rodean el activo que se desea proteger, que son los datos de los clientes. El supuesto de diseño consiste en asumir que cualquier capa puede fallar, de manera que ninguna concentra por sí sola la seguridad del sistema. Un atacante que vulnere el perímetro todavía debe superar el cortafuegos de red, el endurecimiento del sistema operativo, el WAF, los controles de la aplicación y, finalmente, el cifrado de los datos.

Figura 2

Esquema de seguridad por capas de la plataforma de comercio electrónico



Nota. Cada capa opera de forma independiente de las demás. El control transversal de monitoreo atraviesa las seis capas porque registra eventos originados en cualquiera de ellas.

Tabla 2*Controles implementados por capa del esquema de seguridad*

Capa	Componente	Control implementado	Amenaza que mitiga
1. Perímetro	Cloudflare (plan gratuito)	Mitigación de DDoS, red de entrega de contenido, límite de tasa y WAF de borde	Denegación de servicio y tráfico automatizado
2. Red	UFW y fail2ban	Solo los puertos 80 y 443 abiertos; acceso SSH por llave y bloqueo tras intentos fallidos	Escaneo de puertos y fuerza bruta
3. Sistema operativo	Ubuntu Server 26.04 LTS	Hardening según CIS Benchmark, actualizaciones automáticas de seguridad y auditoría con Lynis	Escalada de privilegios y explotación de servicios obsoletos
4. Servidor web y WAF	Nginx y ModSecurity 3.0	OWASP Core Rule Set 4.x con puntuación de anomalía y TLS 1.3	Inyección SQL, XSS e inclusión de archivos
5. Aplicación	Laravel	Autenticación multifactor, control de acceso por roles, validación de entradas y cabeceras CSP y HSTS	Control de acceso roto y secuestro de sesión
6. Datos	MariaDB	Cifrado AES-256 en reposo, tokenización de tarjetas y respaldos cifrados fuera del servidor	Exfiltración y divulgación de datos sensibles

Nota. La capa 1 se contrata en su modalidad gratuita, lo que permite incorporar mitigación de denegación de servicio sin costo adicional para el proyecto.

5. Estándar de Seguridad Informática a Utilizar

El proyecto adopta la norma ISO/IEC 27001:2022 como marco rector, dado que define los requisitos de un sistema de gestión de la seguridad de la información y organiza en su Anexo A un total de 93 controles agrupados en cuatro temas: organizacional, personas, físico y tecnológico. Sobre ese marco se apoyan estándares complementarios que aportan el detalle técnico que la norma deliberadamente no especifica.

Tabla 3

Estándares aplicados y su papel dentro del proyecto

Estándar	Ámbito	Aplicación concreta en el proyecto
ISO/IEC 27001:2022	Sistema de gestión de la seguridad de la información	Marco rector; controles 8.8, 8.16, 8.20, 8.23, 8.24, 8.26 y 8.28 del Anexo A
ISO/IEC 27002:2022	Guía de implementación de los controles	Criterios de configuración del WAF, del cifrado y del registro de eventos
OWASP Top 10:2025	Riesgos críticos en aplicaciones web	Define el catálogo de ataques que el WAF debe detectar y bloquear
OWASP Core Rule Set 4.x	Conjunto genérico de reglas de detección	Reglas cargadas en ModSecurity y ajuste del umbral de anomalía
PCI DSS v4.0, requisito 6.4.2	Protección de datos de tarjetas de pago	Obliga a desplegar el WAF en la aplicación web pública
CIS Benchmark para Ubuntu Linux	Endurecimiento del sistema operativo	Línea base verificable de configuración segura del servidor
NIST SP 800-61r3	Gestión de incidentes de seguridad	Procedimiento de respuesta y escalamiento ante alertas del SIEM
Modelo SKiP (CERT/SEI)	Ciclo de defensa continua	Fases de asegurar, preparar, detectar, responder y mejorar

Nota. Los estándares se aplican de forma complementaria: ISO/IEC 27001 establece qué se debe gestionar, mientras que OWASP, CIS y PCI DSS precisan cómo hacerlo en el plano técnico.

Correspondencia entre las Amenazas Identificadas y los Controles

La infografía analizada en el curso cuantifica la distribución de las vulnerabilidades web más frecuentes. La versión 2025 del OWASP Top 10 reorganizó algunas de esas categorías; en particular, el Cross-Site Scripting quedó consolidado dentro de la categoría de inyección, y las

fallas en la cadena de suministro de software ascendieron al tercer lugar. La siguiente tabla vincula cada amenaza del curso con la categoría vigente y con el control específico que la atiende.

Tabla 4

Correspondencia entre amenazas, categorías OWASP 2025 y controles implementados

Amenaza identificada	Categoría OWASP Top 10:2025	Control implementado
Cross-Site Scripting (14.69 %)	A05:2025 Inyección	Reglas CRS 941.x del WAF y cabecera Content-Security-Policy
Componentes vulnerables (12.36 %)	A03:2025 Fallas en la cadena de suministro de software	Actualizaciones automáticas y auditoría de dependencias con Composer
Autenticación débil (9.25 %)	A07:2025 Fallas de autenticación	Autenticación multifactor, límite de intentos y fail2ban
Inyección SQL (5.55 %)	A05:2025 Inyección	Reglas CRS 942.x del WAF y sentencias preparadas en MariaDB
Configuración insegura del servidor	A02:2025 Configuración de seguridad incorrecta	Hardening conforme al CIS Benchmark y auditoría periódica con Lynis

Nota. Los porcentajes provienen de la infografía de vulnerabilidades web analizada en el curso. La equivalencia con las categorías de 2025 se establece a partir de la clasificación vigente publicada por la Fundación OWASP.

6. Detalle de Herramientas

El criterio de selección privilegió herramientas de código abierto y servicios en su modalidad gratuita, de modo que el costo de licenciamiento del proyecto sea nulo y la solución resulte reproducible por el equipo sin depender de contratos comerciales. Todas las herramientas listadas cuentan con documentación pública y soporte activo de su comunidad.

Herramientas de Desarrollo de Software

Tabla 5

Herramientas de desarrollo seleccionadas

Herramienta	Versión	Función en el proyecto	Licencia y costo
PHP	8.4	Lenguaje del lado del servidor	Open source, Q0.00
Laravel	13	Framework MVC con protección integrada contra CSRF y ORM Eloquent	MIT, Q0.00
Composer	2.x	Gestión y auditoría de dependencias	MIT, Q0.00
Node.js y npm	24 LTS	Compilación de recursos del frontend	MIT, Q0.00
Tailwind CSS	4.x	Framework de estilos de la interfaz	MIT, Q0.00
Visual Studio Code	Estable	Entorno de edición de código	Gratuito, Q0.00
Git y GitHub	Plan Free	Control de versiones y repositorio remoto	Gratuito, Q0.00
Postman	Plan Free	Pruebas funcionales de la interfaz de programación	Gratuito, Q0.00

Sistema Operativo y Plataforma Tecnológica

Tabla 6

Sistema operativo y plataforma de despliegue

Componente	Especificación	Función en el proyecto	Costo mensual
Ubuntu Server	26.04 LTS	Sistema operativo del servidor de producción, con soporte estándar hasta 2031	Q0.00
Nginx	Rama estable	Servidor web y proxy inverso	Q0.00
MariaDB	11.8 LTS	Gestor de la base de datos transaccional	Q0.00

Componente	Especificación	Función en el proyecto	Costo mensual
Servidor virtual privado	2 vCPU, 4 GB RAM, 80 GB SSD	Infraestructura de cómputo del entorno productivo	Q183.00
Respaldos automáticos	Instantáneas semanales	Recuperación ante incidentes o pérdida de datos	Q37.00
Cloudflare	Plan Free	DNS, red de entrega de contenido, anti-DDoS y WAF de borde	Q0.00

Nota. El costo del servidor virtual privado corresponde a una instancia de 24 dólares mensuales convertida al tipo de cambio de referencia de Q7.63 por dólar vigente el 17 de agosto de 2026.

Herramientas de Seguridad y Auditoría

Tabla 7

Herramientas de seguridad, monitoreo y auditoría

Herramienta	Versión	Función en el proyecto	Licencia y costo
ModSecurity	3.0.x	Motor del WAF integrado como módulo de Nginx	Apache 2.0, Q0.00
OWASP Core Rule Set	4.x	Reglas genéricas de detección de ataques web	Apache 2.0, Q0.00
Certbot y Let's Encrypt	Estable	Emisión y renovación automática de certificados TLS	Gratuito, Q0.00
UFW	Estable	Cortafuegos de red del servidor	GPL, Q0.00
fail2ban	Estable	Bloqueo automático de intentos de fuerza bruta	GPL, Q0.00
OWASP ZAP	2.x	Escaneo de vulnerabilidades de la aplicación web	Apache 2.0, Q0.00
Nmap	7.x	Descubrimiento de puertos y servicios expuestos	GPL, Q0.00
Wazuh	4.x	SIEM, detección de intrusiones y monitoreo de integridad	GPL, Q0.00
Lynis	3.x	Auditoría del endurecimiento del sistema operativo	GPL, Q0.00

Nota. La totalidad de las herramientas de seguridad seleccionadas son de código abierto, por lo que el costo de licenciamiento del proyecto asciende a Q0.00.

7. Costo y Tiempo

Estimación de Costos

El presupuesto se expresa en quetzales y se divide en dos bloques. El primero corresponde al desembolso real de efectivo que exige el proyecto, concentrado en la infraestructura de cómputo. El segundo valoriza las horas de trabajo del equipo, que en este caso constituyen un aporte académico y no representan una salida de dinero, pero se cuantifican para dimensionar el esfuerzo real de la implementación.

Tabla 8

Presupuesto de inversión del proyecto en quetzales

Rubro	Detalle	Cantidad	Subtotal (Q)
Servidor virtual privado	Q183.00 mensuales	4 meses	732.00
RespalDOS automáticos	Q37.00 mensuales	4 meses	148.00
Dominio de Internet	Registro anual .com	1 año	92.00
Certificado TLS	Let's Encrypt	Ilimitado	0.00
Servicio de WAF de borde	Cloudflare, plan Free	4 meses	0.00
Licencias de software	Ubuntu, Nginx, MariaDB, PHP, Laravel, ModSecurity, CRS, Wazuh, ZAP, Nmap y Lynis	11 productos	0.00
Subtotal de desembolso			972.00
Reserva de contingencia	10 % del subtotal		97.20
Total de desembolso real			1,069.20

Nota. Los montos en dólares se convirtieron al tipo de cambio de referencia de Q7.63 por dólar vigente el 17 de agosto de 2026. Las cifras son estimaciones sujetas a variación cambiaria.

Tabla 9

Valorización del talento humano del equipo

Concepto	Tarifa referencial	Horas	Subtotal (Q)
Beteta García, D. A.	Q40.00 por hora	120	4,800.00
Herrera Soto, J. R.	Q40.00 por hora	120	4,800.00
Rompich Yoc, M. R.	Q40.00 por hora	120	4,800.00

Concepto	Tarifa referencial	Horas	Subtotal (Q)
Total de talento humano		360	14,400.00
Valor total del proyecto	Desembolso más talento humano		15,469.20

Nota. Las horas del equipo constituyen un aporte académico y no generan desembolso. Se valorizan a una tarifa referencial de mercado para desarrolladores de nivel inicial en Guatemala, con el fin de dimensionar el costo real que tendría la solución en un entorno comercial.

Cronograma de Ejecución

El proyecto se ejecuta en 16 semanas distribuidas en siete fases. Las fases de aprovisionamiento e implementación del WAF concentran la mayor carga de trabajo, mientras que la fase de pruebas se programa antes de la puesta en producción para permitir el ajuste de las reglas que generen falsos positivos.

Tabla 10

Cronograma de ejecución por fases

Fase	Actividad	Semanas	Duración	Horas
1	Análisis de requerimientos y evaluación de riesgos	1 a 2	2 semanas	40
2	Diseño de la arquitectura y del esquema de seguridad	3 a 4	2 semanas	40
3	Aprovisionamiento de la infraestructura y hardening del servidor	5 a 7	3 semanas	65
4	Implementación del WAF: ModSecurity, CRS y Cloudflare	8 a 10	3 semanas	70
5	Desarrollo e integración de la aplicación de comercio electrónico	11 a 13	3 semanas	70
6	Pruebas de intrusión y ajuste de reglas del WAF	14 a 15	2 semanas	50
7	Documentación, capacitación y puesta en producción	16	1 semana	25
	Total	1 a 16	16 semanas	360

Nota. La carga total de 360 horas equivale a un promedio de 7.5 horas semanales por integrante durante las 16 semanas del proyecto.

Entregables por Fase

- **Fases 1 y 2.** Matriz de riesgos, inventario de activos y diseño del esquema de seguridad por capas.
- **Fases 3 y 4.** Servidor endurecido conforme al CIS Benchmark y WAF operativo con reglas ajustadas.
- **Fase 5.** Aplicación de comercio electrónico funcional e integrada con los controles de seguridad.
- **Fase 6.** Informe de pruebas de intrusión con hallazgos, evidencias y acciones correctivas.
- **Fase 7.** Manual de operación, política de seguridad documentada y sistema en producción.

Referencias

Canonical. (2026). Ubuntu 26.04 LTS (Resolute Raccoon) release notes.

<https://documentation.ubuntu.com/release-notes/26.04/>

Center for Internet Security. (2025). CIS Ubuntu Linux benchmark.

https://www.cisecurity.org/benchmark/ubuntu_linux

DigitalOcean. (2026). Droplet pricing. <https://www.digitalocean.com/pricing/droplets>

Organización Internacional de Normalización. (2022). ISO/IEC 27001:2022. Seguridad de la información, ciberseguridad y protección de la privacidad. Sistemas de gestión de la seguridad de la información. Requisitos.

Organización Internacional de Normalización. (2022). ISO/IEC 27002:2022. Controles de seguridad de la información.

OWASP Foundation. (2025). OWASP Top 10:2025. <https://owasp.org/Top10/2025/>

OWASP Foundation. (2026). OWASP Core Rule Set. <https://coreruleaset.org/>

PCI Security Standards Council. (2024). Payment Card Industry Data Security Standard: Requirements and testing procedures (v4.0.1).

Rompich Yoc, M. R., Herrera Soto, J. R., y Beteta García, D. A. (2026). Propuesta de proyecto de curso: Plataforma de comercio electrónico (E-Commerce SaaS) [Documento de trabajo]. Universidad Mariano Gálvez de Guatemala.

Wise. (2026, 17 de agosto). Tipo de cambio del quetzal guatemalteco al dólar estadounidense. <https://wise.com/us/currency-converter/gtq-to-usd-rate/history>